

DIGITAL FORENSICS

د. يوسف باخدلحي – Dr. Yousef Bakhdlaghi
Assistant Professor, Department of Cybersecurity, UJ
Email: ybakhdlaghi@uj.edu.sa

References

- Guide to Computer Forensics and Investigations, 7th Edition,
 - Bill Nelson, et al. Cengage, 2025
- Digital Forensics and Incident Response, 4th Edition,
 - Gerard Johansen, Packt, 2025
- Roadmap of digital forensics investigation process with discovery of tools, Cyber Security and Digital Forensics,
 - Anita Patil, et al. (2022):241-269.
- SWGDE 18-F-001-2.0 / SWGDE 18-F-002-2.0 /
- SWGDE 17-F-002-2.1 / SWGDE 23-Q-001-1.1 /
- NIST SP 800-61 Rev. 3
- IETF RFC 3227
- <https://www.sans.org/blog>

Outline

- **Day 1:** Introduction to Forensics
 - Lab: Malware Behavioral Analysis
- **Day 2:** Acquisition
 - Lab: Live System Acquisition
- **Day 3:** Examination & Analysis (Win PE, Files, & Memory)
 - Lab: Examination – Part 1
- **Day 4:** Examination & Analysis (Network) & Reporting
 - Lab: Examination – Part 2

INTRODUCTION TO DIGITAL FORENSICS

What is Digital Forensics?

- **Digital forensics** is the disciplined process of:
 - identifying
 - acquiring
 - preserving
 - examining & analyzing
 - and reporting digital evidence
- to reconstruct the facts of an incident and present them in a technically sound and legally defensible manner

What is Digital Forensics?

- Cybersecurity teams can use digital forensics to understand
 - what happened,
 - how it happened, and
 - what evidence can support an investigation

Digital Forensics Investigations

- Public-sector investigations
 - as part of **law enforcement** or state authority, with a strong focus on criminal procedure, warrants, admissibility, and prosecution.
- Private-sector investigations
 - to **protect an organization's interests**, respond to incidents, support civil litigation, or meet regulatory obligations.
 - Its work may still need to be court-ready, but the investigation is normally **driven by business** rather than police powers.

Digital Forensics Terms

- Line of authority
 - States who has the legal right to initiate an investigation, who can take possession of evidence, and who can have access to evidence
- Chain of custody
 - Route the evidence takes from the time you find it until the case is closed or goes to court
 - it proves who handled the digital evidence, when they handled it, where it was stored, what was done to it, and whether it remained unchanged.
 - <https://www.nist.gov/document/sample-chain-custody-formdocx>

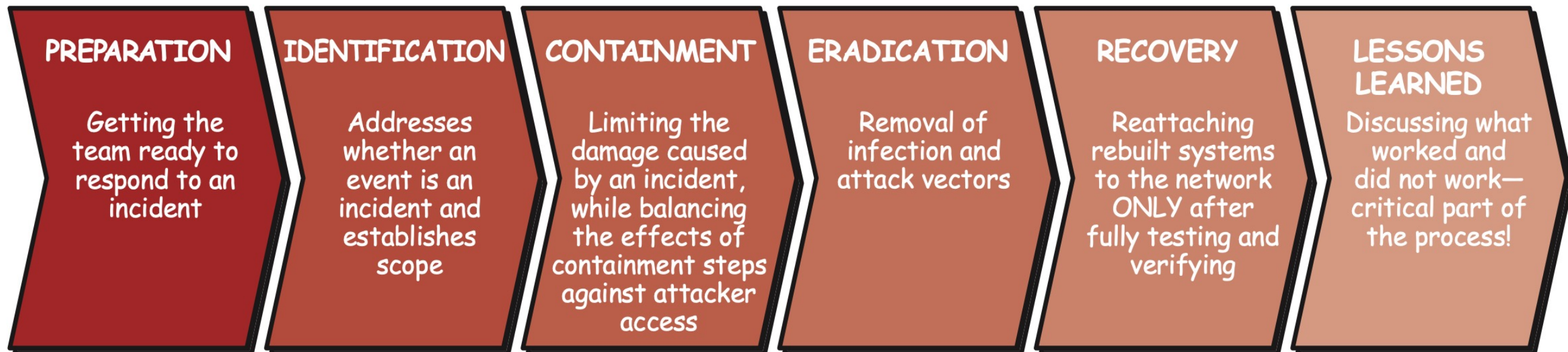
Digital Forensics Terms

- Digital Evidence
 - Any stored or transmitted information in digital form that may be of value to an investigation
 - e.g., malware, files, emails, digital photos, system/network logs..., etc

Incident Response

- Incident Response:

The planned and managed effort by an organization to respond to a computer security incident.



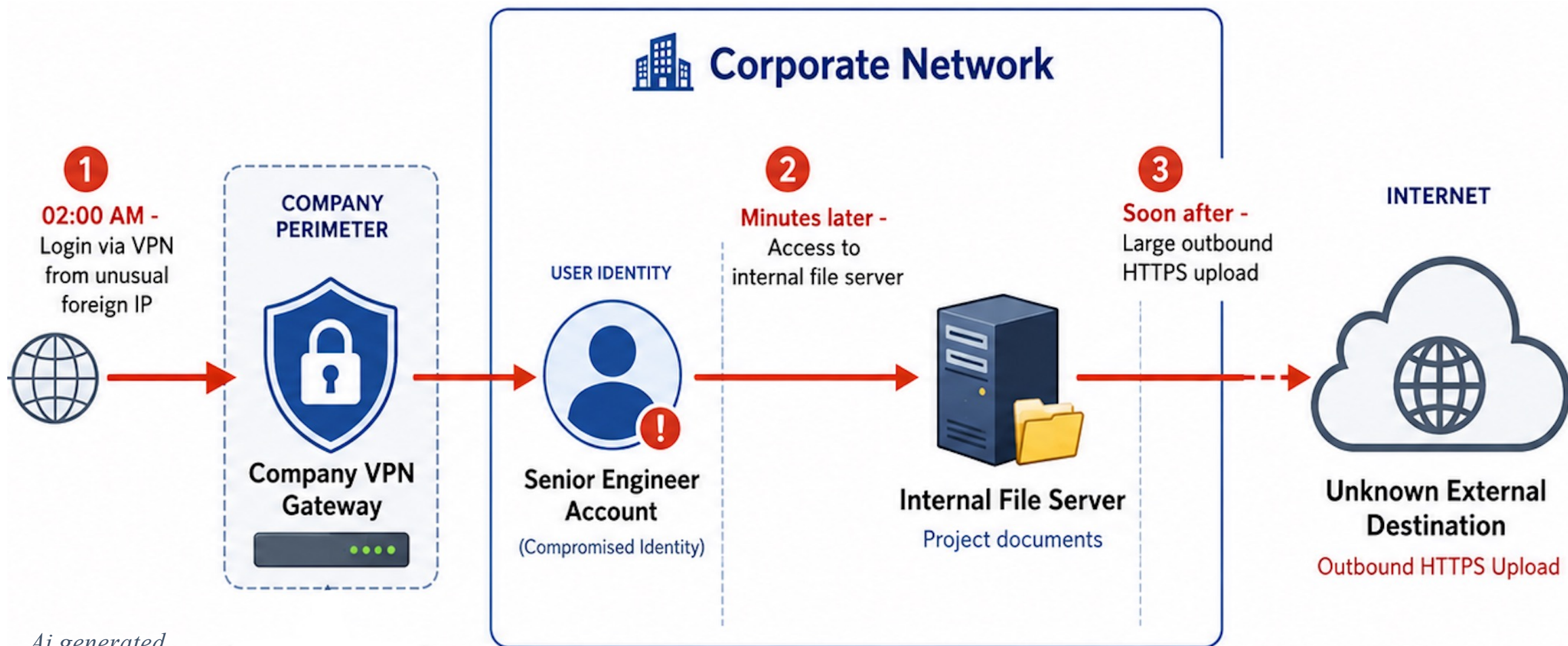
Source: <https://www.sans.org/security-resources/glossary-of-terms/incident-response>

CASE STUDY

Case – *Credential compromise and possible data exfiltration*

- At 02:00 AM, a senior engineer's account **logs in** through the company **VPN** from an **unusual foreign IP** address.
- Minutes later, the account **accesses an internal file server** containing project documents.
- Soon after, the same session generates a **large outbound HTTPS upload** to an unknown **external destination**.
- The engineer says he did not perform this activity.
- The **company suspects** credential compromise and possible data exfiltration.

Case – *Credential compromise and possible data exfiltration* – sources of evidence?



Case – *Credential compromise and possible data exfiltration*

- What evidence sources would you examine in this incident, and what traces would you expect to find in each location?
- WHAT IF NO EVIDENCE? → PREPARATION

KSA Anti-Cybercrime Law



- Core offences
 - Unauthorized access, interception & website hacking
 - Privacy invasion, digital defamation & online blackmail
 - Fraud, false identity & illegal bank/credit data access
 - Private-data leakage/destruction & service disruption
 - Illegal content; terrorist, security or economic threats

Rules of evidence, Legal Proceedings

- **Rules of evidence** determine what types of evidence is admissible and legally accepted in court.
 - https://www.law.cornell.edu/wex/admissible_evidence
- Best Practices for Personnel Presenting Digital Evidence in **Legal Proceedings**
 - <https://www.swgde.org/wp-content/uploads/2024/04/2024-02-02-SWGDE-Best-Practices-for-Personnel-Presenting-Digital-Evidence-in-Legal-Proceedings-23-Q-001-1.1.pdf>

Digital Forensics Challenges

- Anti-forensics techniques (encryption, steganography, wiping)
- Time constraints
- Evidence size
- Volatile data loss
- Cloud complexity
- Mobile devices & IoT
- Rapid technology change
- Cross-border jurisdiction problems

Digital Forensics Readiness (Preparation)

- Train analysts and incident responders
- Prepare standard procedures for evidence
 - collection, imaging, examination, reporting, evidence storage, tool use, and escalation.
- Develop Internal Visibility for organizations (host/network)
 - Identify existing sources and gaps (blind spots)
 - Hosts/servers logs, network logs, pcap, netflow

Digital Forensics Readiness (Preparation)

- Prepare a forensic “jump kit”
 - laptops, forensic workstation, connectors/adapters, blank storage media, write-blockers
- Plan for specific technologies (Windows, macOS, iOS, ...)
- Prepare communication channels:
 - contact lists, escalation paths, legal contacts, secure communication methods.
- Run exercises and simulations: test staff, tools, communication channels, legal escalation, and evidence handling

Pre-Investigation Engagement

- Type of case: fraud, data leakage, security incident, ...
- Objectives/Scope of investigation
- Identify evidence sources
- Confirm legal authority: **obtain** consent, warrant, internal authorization, before collection and investigation
- Collect reference information in advance
 - asset inventories, network diagrams, critical-system lists, application documentation, port lists, baseline activity, and known-good file hashes.
- Chain of Custody

Anti-Forensics Techniques – Encryption

- Examiners should **be aware** of encryption technologies at the device, volume, container, and file level.
- To obtain encryption keys, examiners may need to capture memory prior to obtaining a disk image and attempt to decrypt later.
- Examiners may choose to perform a **live acquisition** of source media to obtain logical images of decrypted data.
- Some encryption technologies allow saving of recovery keys locally, in the cloud, or via an enterprise management solution.
- May obtain encryption keys or unencrypted data via non-technical means.

Anti-Forensics Techniques – Steganography

- Steganalysis - term for detecting and analyzing steganography files
- If you encrypt a plaintext file with PGP and insert the encrypted text into a steganography file
 - Cracking the encrypted message is extremely difficult

Recovering Encryption Keys/Passwords

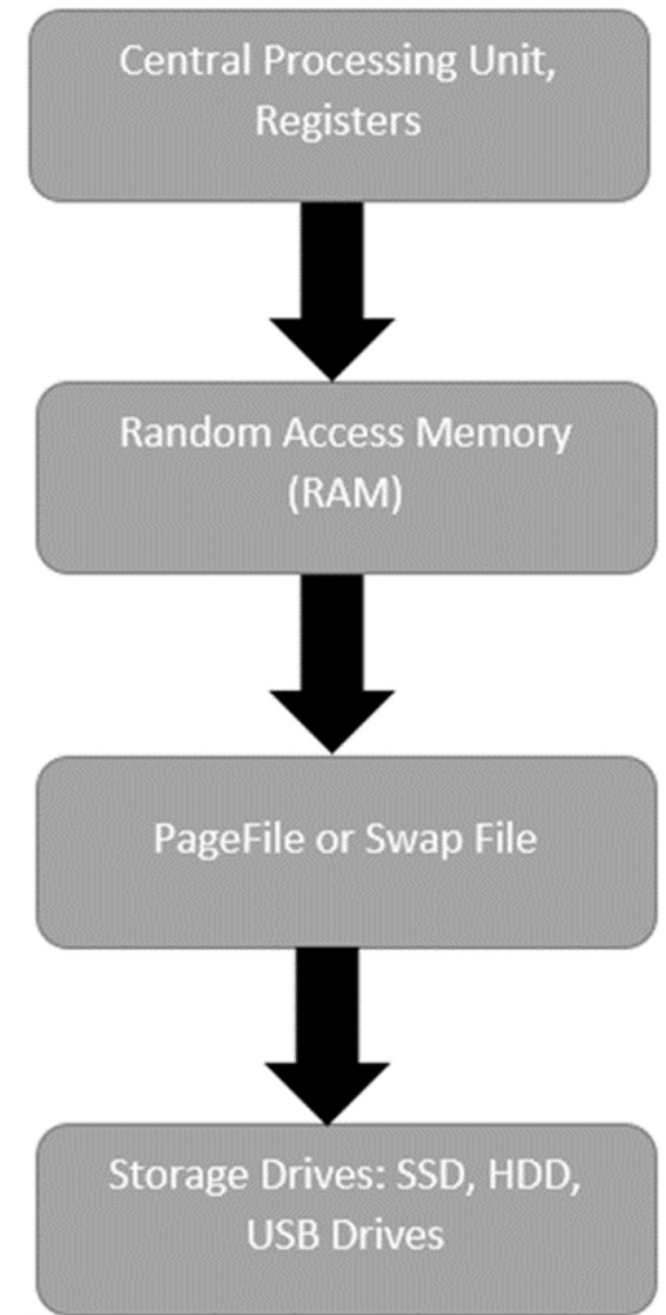
- Password-cracking tools are available for handling password-protected data or systems
 - Brute-force attacks
 - Dictionary attack

Digital Forensics Paths

- Cybercrime Investigator
- Expert Witness
 - Presents technical findings in court and explains digital evidence to judges,
- Computer Forensics
 - Windows, Linux, Mac
- Mobile / IoT Forensics
- Network Forensics
- Cloud Forensics
- Reverse Engineering (Malware Analysis)

Order of Volatility

- Volatility is used to describe how data on a host system is maintained after changes
 - such as logoffs or power shutdowns.
- Data that will be **lost** if the system is powered down is referred to as volatile data.
- The most critical pieces of volatile evidence is the **memory (RAM)** currently running on the system.



Storage Devices

Mechanical HDD

- Stores data magnetically on spinning disks.
- can be damaged by sudden sharp movement/drop or a mechanical shock

SSD

- Stores data in flash memory.
- No moving parts or spinning disks

Storage Devices – Data Recovery

Mechanical HDD

- Deleted files often **remain recoverable until overwritten.**
- Data persistence Deleted data may remain for a long time

SSD

- Deleted data is **harder to recover** because of
 - wear-leveling,
 - TRIM
 - garbage collection.
- Deleted blocks may be **erased automatically**

Storage Devices

- **TRIM** marks deleted blocks as no longer needed.
 - Internal **garbage collection** may later erase those blocks.
 - The result can be similar to wiping because the deleted data may become permanently unrecoverable.
- All SSD have a feature called **wear-leveling**
 - An internal firmware feature used in solid-state drives that ensures even wear of read/writes for all memory cells

Physical Disk vs Partitions

- A **physical disk** is the entire storage device,
 - including all partitions, unallocated space, boot records, hidden areas, and deleted data remnants.
- A partition is a logical drive inside the disk
- **Imaging the physical** disk is more complete
 - because it captures everything on the device,
- while **imaging only a partition** may miss important evidence such as deleted partitions, slack space, unallocated space, and boot-level artifacts.

Physical Disk vs Partitions

- The partition table is in the **Master Boot Record (MBR)**
 - Located at sector 0 of the disk drive
 - (Sector numbers are called physical addresses)
- Sector vs cluster
 - Sector: The smallest physical storage
 - Cluster: A group of one or more sectors used by the file system to store files

Core Digital Forensics Process



Core Digital Forensics Process

- **Acquisition** – Collect and create a forensic copy of digital evidence while preserving its integrity, usually using write blockers and hash verification.
- **Examination** – Analyze the acquired data to identify, recover, and interpret relevant artifacts and evidence.
- **Reporting** – Document the methods, tools, findings, and conclusions in a clear, accurate, and c manner.

Lab 1: Malware Behavioral Analysis